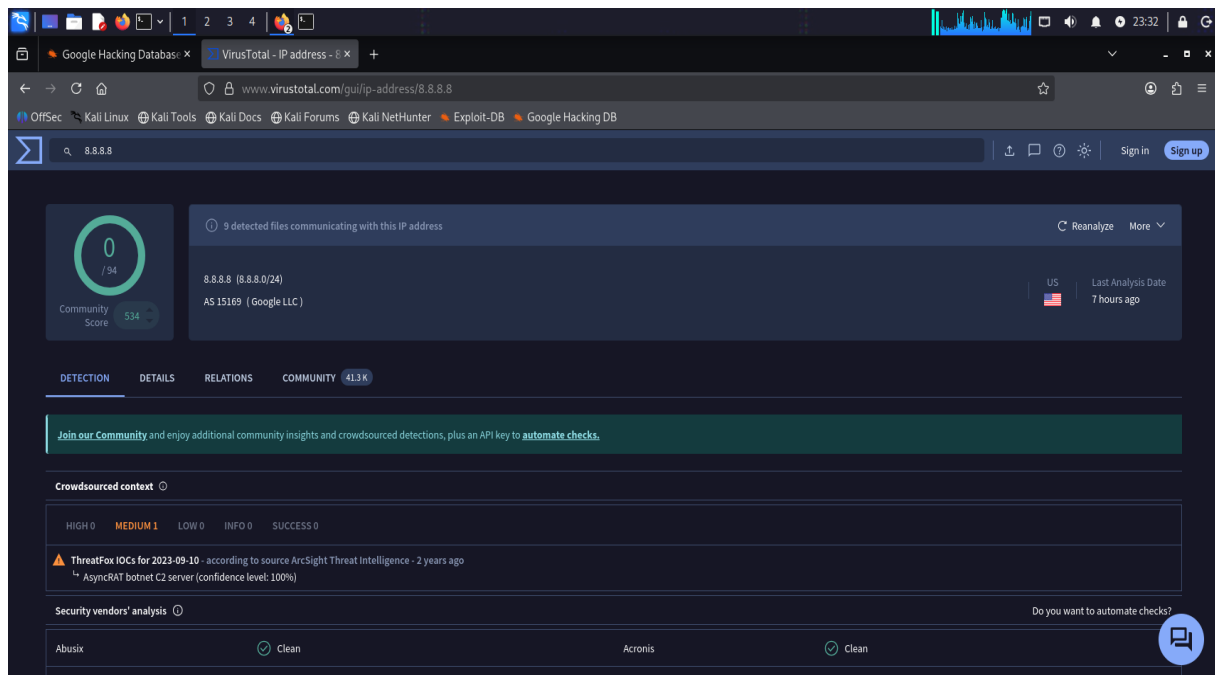


COMPTE RENDU DE TP 1.3 : Introduction à la Threat Intelligence et recherche de vulnérabilités

1. Introduction

- Définition de la Threat Intelligence : La Threat Intelligence (ou renseignement sur les menaces) est le processus de collecte, d'analyse et de contextualisation des données relatives aux cyber menaces actuelles ou potentielles. Elle vise à comprendre les méthodes, les cibles et les infrastructures des attaquants.
- Rôle dans la cyber sécurité : Elle permet aux équipes de sécurité de passer d'une posture réactive à une posture proactive. En connaissant les menaces à l'avance, une organisation peut prioriser ses correctifs de sécurité, adapter ses défenses (règles pare-feu, détection d'intrusions) et mieux anticiper les attaques avant qu'elles ne se produisent.

2. Analyse de l'adresse IP



- Interprétation du score : L'analyse de l'adresse IP 8.8.8.8 sur Virus Total renvoie un score de 0/90, ce qui signifie qu'aucun moteur de sécurité ou fournisseur d'antivirus ne la considère comme malveillante.
- Conclusion sur la dangerosité : Cette adresse IP n'est pas dangereuse. Il s'agit d'une adresse légitime bien connue : c'est le serveur DNS public principal de Google. Les communications vers cette IP dans un réseau sont normales.

3. Analyse des services

```
morel@kali: ~  
$ nmap -sS 192.168.56.10  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 12:56 +0200  
Nmap scan report for 192.168.56.10  
Host is up (0.018s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 00:0C:29:4C:4E:DB (VMware)  
Nmap done: 1 IP address (1 host up) scanned in 4.95 seconds  
  
morel@kali: ~  
$ nmap -sV 192.168.56.10  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 12:57 +0200  
Nmap scan report for 192.168.56.10  
Host is up (0.00091s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))  
MAC Address: 00:0C:29:4C:4E:DB (VMware)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 11.26 seconds  
  
morel@kali: ~  
$
```

- Identification d'un service : Sur la base des résultats de balayage, nous avons identifié le service web Apache version 2.4.41.

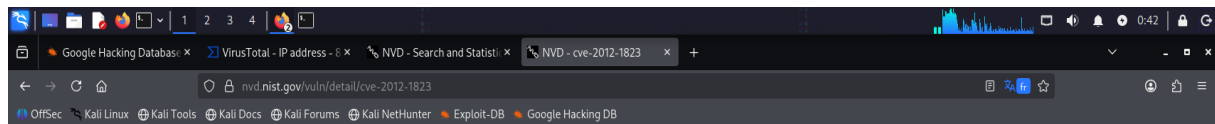
```
morel@kali: ~  
$ searchsploit apache  


| Exploit Title                                                                 | Path                              |
|-------------------------------------------------------------------------------|-----------------------------------|
| Apache (Windows x86) - Chunked Encoding (Metasploit)                          | linux/windows/x86/remote/16782.rb |
| Apache - PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution               | linux/php/remote/29298.c          |
| Apache - PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner             | linux/php/remote/29316.py         |
| Apache - Arbitrary Long HTTP Headers (Denial of Service)                      | linux/multiple/dos/360.pl         |
| Apache - Arbitrary Long HTTP Headers Denial of Service                        | linux/linux/dos/371.c             |
| Apache - Denial of Service                                                    | linux/linux/dos/18221.c           |
| Apache - httponly cookie Disclosure                                           | linux/multiple/remote/18442.html  |
| Apache - Remote Memory Exhaustion (Denial of Service)                         | linux/multiple/dos/17696.pl       |
| Apache 0.8.x/1.0.x / NCSA HTTPD 1.x - 'test-cgi' Directory Listing            | linux/cgi/remote/28435.txt        |
| Apache 1.0/1.2/1.3 - Server Address Disclosure                                | linux/multiple/remote/21067.c     |
| Apache 1.1 / NCSA HTTPD 1.5.2 / Netscape Server 1.12/1.1/2.0 - a nph-test-cgi | linux/multiple/dos/19536.txt      |
| Apache 1.2 - Denial of Service                                                | linux/multiple/dos/20558.txt      |
| Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME Header Denial of Service            | linux/windows/dos/20272.pl        |
| Apache 1.3 - PHP 3 - File Disclosure                                          | linux/multiple/remote/20466.txt   |
| Apache 1.3 - Artificially Long Slash Path Directory Listing (1)               | linux/multiple/remote/20692.pl    |
| Apache 1.3 - Artificially Long Slash Path Directory Listing (2)               | linux/multiple/remote/20693.c     |
| Apache 1.3 - Artificially Long Slash Path Directory Listing (3)               | linux/multiple/remote/20694.pl    |
| Apache 1.3 - Artificially Long Slash Path Directory Listing (4)               | linux/multiple/remote/20695.pl    |
| Apache 1.3 - Directory Index Disclosure                                       | linux/multiple/remote/21002.txt   |
| Apache 1.3.12 - WebDAV Directory Listings                                     | linux/linux/remote/20210.txt      |
| Apache 1.3.14 - Mac File Protection Bypass                                    | linux/osx/remote/20911.txt        |
| Apache 1.3.20 (Win32) - 'PHP.exe' Remote File Disclosure                      | linux/windows/remote/21204.txt    |
| Apache 1.3.31 mod_include - Local Buffer Overflow                             | linux/linux/local/587.c           |
| Apache 1.3.34/1.3.33 (Ubuntu / Debian) - CGI TTY Privilege Escalation         | linux/linux/local/3384.c          |
| Apache 1.3.35/2.0.58/2.2.2 - Arbitrary HTTP Request Headers Security          | linux/linux/remote/28424.txt      |
| Apache 1.3.6/1.3.9/1.3.11/1.3.12/1.3.20 - Root Directory Access               | linux/windows/remote/19975.pl     |
| Apache 1.3.x - Tomcat 4.0.x/4.1.x mod_jk - Chunked Encoding Denial of Service | linux/unix/dos/22068.pl           |
| Apache 1.3.x - HTDigest Realm Command Line Argument Buffer Overflow (1)       | linux/unix/remote/25624.c         |
| Apache 1.3.x - HTDigest Realm Command Line Argument Buffer Overflow (2)       | linux/unix/remote/25625.c         |
| Apache 1.3.x < 2.0.48 mod_userdir - Remote Users Disclosure                   | linux/linux/remote/132.c          |
| Apache 1.3.x mod_include - Local Buffer Overflow                              | linux/linux/local/21494.c         |
| Apache 1.3.x mod_mylo - Remote Code Execution                                 | linux/multiple/remote/67.c        |
| Apache 1.3/2.0.x - Server Side Include Cross-Site Scripting                   | linux/multiple/remote/21885.txt   |
| Apache 1.4/2.2.x - APR 'apr_fmatch()' Denial of Service                       | linux/linux/dos/35738.php         |
| Apache 1.x/2.0.x - Chunked-Encoding Memory Corruption (1)                     | linux/multiple/remote/21559.c     |
| Apache 1.x/2.0.x - Chunked-Encoding Memory Corruption (2)                     | linux/multiple/remote/21560.c     |
| Apache 2.0 - Encoded Backslash Directory Traversal                            | linux/windows/remote/21697.txt    |
| Apache 2.0 - Full Path Disclosure                                             | linux/windows/remote/21719.txt    |
| Apache 2.0 mod_ssl 2.0.2 (Windows x86) - Remote Buffer Overflow               | linux/windows/x86/remote/5330.c   |
| Apache 2.0.39/40 - Oversized STDERR Buffer Denial of Service                  | linux/linux/dos/21854.c           |
| Apache 2.0.44 (Linux) - Remote Denial of Service                              | linux/linux/dos/11.c              |


```

- Explication des vulnérabilités : L'outil searchsploit interroge la base de données locale Exploit-DB. Pour la version Apache 2.4.41, l'outil révèle plusieurs vulnérabilités critiques publiquement connues et Remote Code Execution (exécution de code à distance). Cela signifie que des scripts d'exploitation (exploits) sont déjà disponibles publiquement pour attaquer cette version spécifique.

4. Étude d'une CVE (Exemple : CVE-2021-41773)



CVE-2012-1823 Détail

DIFFÉRÉ

Ce dossier CVE n'est pas priorisé pour les efforts d'enrichissement de la NVD en raison de ressources ou d'autres préoccupations.

Description

sapi/cgi/_main.c en PHP avant 5.3.12 et 5.4.x avant 5.4.2, lorsqu'il est configuré en tant que script CGI (alias php-cgi), ne gère pas correctement les chaînes de requêtes qui manquent d'un caractère = (signe égal), ce qui permet aux attaquants distants d'exécuter du code arbitraire en plaçant des options en ligne de commande dans la chaîne de requête, liées au manque de saut d'un certain php_getopt.

Métriques

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

Les efforts d'enrichissement de la NVD font référence à l'information accessible au public à l'associé chaînes vectorielles. L'information CVSS fournie par d'autres sources est également affichée.

CVSS 3.x Gravité et chaînes vectorielles:



NIST: NVD

Base Score: 9.8 CRITIQUE

Vecteur: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

ADP: CISA-ADP

Base Score: 9.8 CRITIQUE

Vecteur: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

QUICK INFO

Entrée du dictionnaire CVE:

[CVE-2012-1823](#)

NVD Date de publication:

05/11/2012

NVD Dernière modification:

Catégorie: 11/04/2025

Source:

CERT/CC

Références aux outils, solutions et outils

- Description : Une faille a été découverte dans la normalisation des chemins d'accès dans le serveur HTTP Apache 2.4.41. Un attaquant peut utiliser une attaque par traversée de chemin pour mapper des URL vers des fichiers situés en dehors de la racine des documents attendue.
- Impact : L'impact est très sévère. Cela permet la fuite d'informations (lecture de fichiers sensibles du système comme /etc/passwd) et, si les scripts CGI sont activés, cela peut mener à une exécution de code arbitraire à distance (RCE).
- Niveau de gravité : Critique. Le score CVSS (Common Vulnerability Scoring System) est généralement de 9.8/10.
- Exploitation possible : Oui, la faille est exploitable à distance via de simples requêtes HTTP malveillantes (sans nécessiter d'authentification préalable).

5. Utilisation avancée de searchsploit

Voici 3 options avancées utiles pour un analyste :

Option 1 : searchsploit -x <chemin>

- Son rôle : Permet d'examiner le code source d'un exploit directement dans le terminal (ouvre un pager).
- Exemple : searchsploit -x exploits/linux/remote/50383.sh

- Son utilité : Avant de lancer un code téléchargé sur internet, un professionnel de la sécurité doit toujours le lire pour comprendre son fonctionnement exact, vérifier qu'il n'est pas piégé, et voir s'il y a des variables à modifier (comme l'IP cible).

Option 2: searchsploit -m <id> (Mirroring / Copie)

- Son rôle : Copie (miroir) le fichier de l'exploit depuis la base de données locale vers le répertoire de travail actuel de l'utilisateur.
- Exemple : searchsploit -m 50383
- Son utilité : Très pratique pour récupérer rapidement l'exploit afin de le compiler (s'il s'agit d'un code C), le modifier ou l'exécuter directement lors d'un test d'intrusion.

Option 3 : Mots-clés précis searchsploit apache 2.4.49 (Filtrage strict)

- Son rôle : Effectue une recherche ciblée en utilisant la version exacte du logiciel.
- Exemple : searchsploit apache 2.4.41
- Son utilité : Évite le bruit. Une recherche sur "apache" seul renverrait des milliers de résultats inutilisables. La précision permet de trouver uniquement les exploits qui fonctionneront sur la cible spécifique analysée.

6. Analyse globale de sécurité

- Les risques identifiés sont : Le système cible est exposé à un risque critique de vol de données sensibles et de prise de contrôle total par un attaquant distant non authentifié.
- Le service le plus dangereux est : Le service web Apache est actuellement le plus dangereux car il est la porte d'entrée exposée au réseau présentant des vulnérabilités critiques facilement exploitables.
- Les actions recommander sont :
 1. Mettre à jour immédiatement le service Apache vers une version sécurisée.
 2. Désactiver l'exécution des scripts CGI si elle n'est pas strictement nécessaire.
 3. Mettre en place des règles sur un WAF (Web Application Firewall) pour bloquer les requêtes contenant des motifs de "Path Traversal".

7. Lien avec l'entreprise

- Comment un SOC utilise la Threat Intelligence : Un SOC (Security Operations Center) intègre des flux de Threat Intelligence pour enrichir ses outils (SIEM). Cela permet de détecter si une adresse IP interne communique avec une IP externe connue pour être

malveillante, ou d'identifier immédiatement si un logiciel utilisé en interne fait l'objet d'une nouvelle vulnérabilité (CVE) fraîchement publiée.

- Comment anticiper une attaque : En surveillant activement les bases de données de vulnérabilités (OSINT) et les forums de sécurité, les équipes peuvent appliquer des correctifs avant que les attaquants n'aient le temps d'automatiser l'exploitation de la faille à grande échelle.

8. Conclusion

- Ce TP m'a permis de comprendre concrètement comment utiliser des sources d'informations publiques (OSINT) comme Virus Total et NVD, ainsi que des outils d'analyse (Searchsploit), pour évaluer la dangerosité d'une cible. J'ai appris à faire le pont entre un simple numéro de version de logiciel et l'identification d'une menace critique réelle.
- Limites de l'analyse : Les bases de données publiques ne recensent que les vulnérabilités et les malwares connus. Cette méthode est aveugle face aux attaques de type "Zero-Day" (failles non encore publiques) ou face à des infrastructures d'attaque créées le jour même (qui n'auraient pas encore une mauvaise réputation sur Virus Total). De plus, un résultat dans searchsploit ne garantit pas que l'exploit fonctionnera à 100% dans tous les environnements (des protections système peuvent exister).
- Vision proactive : L'information publique est en effet une arme à double tranchant ; elle sert aux attaquants pour trouver des failles, mais elle est indispensable aux défenseurs pour fermer ces brèches de manière proactive.